Task-Scoped Runtime Authorization for Industrial AI Agents

Student Name: Can Baturlar

Student ID: 2506789

1. The Purpose of the Work

An agent allowed to use a business tool may still access an unrelated record or make changes beyond its assigned task. Building on established runtime authorization methods, this thesis will evaluate whether task-bound permissions provide additional protection while preserving legitimate work in a simulated order-management workflow.

RQ1: How do tool-name permissions, standing argument restrictions, and additional task-bound constraints differ in executed authorization violations and authorized task completion?

RQ2: What execution costs do these configurations introduce, and how do incomplete or overly broad task permissions affect task-bound enforcement?

2. Methods and Materials

A Python prototype will connect one tool-using AI agent to a resettable order service with synthetic data and tools for order lookup, inventory checks, and draft management. Every tool execution will pass through a deterministic authorization gateway. Three configurations will enforce: permitted tool names for the task type; the same permissions plus standing argument restrictions, such as approved products and quantity ceilings; and those restrictions plus task-specific record, field, and effect limits. A trusted application will supply task permissions independently of model output.

The evaluation will combine direct authorization checks with repeated agent runs with a small selection of tool-using LLMs on held-out scenario families. Scenarios will include legitimate work, benign overreach, and instructions injected into tool responses, with matched authorized controls and cases where simpler restrictions suffice. Each legitimate task will have a verified authorized solution. For each model, model settings, tool definitions, initial states, task instructions, denial format, and step budget will be matched across configurations. Policies and prompts will be frozen after a development pilot, which will determine the final experiment size and cost.

An independent evaluator will check access logs, intermediate state changes, and final outcomes against intended authority. Measurements will distinguish prohibited attempts from executed violations and report completion without violations, false denials, local checking latency, total runtime, and model calls and tokens. Paired comparisons and confidence intervals will account for related scenario variants and repetitions. A separate sensitivity analysis will alter supplied task permissions while keeping intended authority fixed.

3. Expected Results

Expected outputs are an enforcement prototype, reproducible evaluation scenarios, and evidence on the protection, completion, and cost trade-offs of the three configurations. The study will identify where task context adds value and where restrictions hinder legitimate work. Conclusions will be bounded by the simulated workflow, evaluated models, and assumptions about complete mediation and trustworthy task permissions.